

Gap-analyse logging — OpenMRS LegacyUI

IN-B2.4 Security · Sprint 3, stap 2 · NEN-7510:2024-2 §8.15 (A.8.15)
Module: **openmrs-module-legacyui** · Platform: OpenMRS 2.0.0

1. Scope en normkader

Deze gap-analyse inventariseert de logging-coverage van de LegacyUI-module op basis van statische code-analyse (STAP 1–6). Het normkader is NEN-7510:2024-2 beheersmaatregel **8.15 (Logging)**, dat eist dat beveiligingsrelevante gebeurtenissen worden vastgelegd, inclusief authenticatie, autorisatiefouten, wijzigingen in patiënt- en gebruikersgegevens en beheerhandelingen. Gevoelige gegevens (PGI/PHI) mogen *niet* in logregels verschijnen.

2. Inventarisatie — Event × logging-dekking

Event	Locatie	Gelogd ?	Gevoelige data	Compliant §8.15	Risico
Login succes	LoginServlet:137	NEE	JA — gebruikersnaam	NEE	HOOG
Login gefaald	LoginServlet:190	NEE	JA — gebruikersnaam + IP	NEE	KRITIEK
Logout	LogoutServlet:41	NEE	JA — sessie-ID	NEE	HOOG
Toegang geweigerd (privilege)	RequireTag / LoginController	NEE	JA — gebruiker + resource	NEE	HOOG
createUser / deleteUser	UserFormController:285	NEE	JA — NAW-gegevens gebruiker	NEE	KRITIEK
Wachtwoord wijzigen	OptionsFormController / ChangePasswordFormController	NEE	JA — gebruiker-ID	NEE	HOOG
voidPatient	PatientListController:70	NEE	JA — patiënt-ID	NEE	KRITIEK
unvoidPatient	PatientFormController:278	NEE	JA — patiënt-ID	NEE	HOOG
updatePatient	DWRPatientService:634	NEE	JA — patiëntgegevens	NEE	HOOG
Brute-force (wachtwoordherstel)	ForgotPasswordFormController:59	NEE	JA — e-mail + IP	NEE	HOOG
Module laden / starten	ModuleListController	DEELS	NEE	DEELS	MIDDEL
Server-log toegang	ServerLogController:79,90,93	JA	NEE	JA	—

Event	Locatie	Gelogd ?	Gevoelige data	Compliant §8.15	Risico
Credential in request-param	PostHl7Controller :39-41	N.v.t.	JA — plaintext password	NEE	KRITIEK

3. Toelichting per bevinding

Login succes — HOOG

Locatie: LoginServlet:137 · Gelogd: NEE · Compliant: NEE
Context.authenticate() slaagt; geen log.* aanroep na succes

Login gefaald — KRITIEK

Locatie: LoginServlet:190 · Gelogd: NEE · Compliant: NEE
Teller in-memory (reset bij herstart); geen persistente audit-entry

Logout — HOOG

Locatie: LogoutServlet:41 · Gelogd: NEE · Compliant: NEE
Context.logout() zonder enige log-aanroep

Toegang geweigerd (privilege) — HOOG

Locatie: RequireTag / LoginController · Gelogd: NEE · Compliant: NEE
Spring Security weigering; geen audit-log in LegacyUI zelf

createUser / deleteUser — KRITIEK

Locatie: UserFormController:285 · Gelogd: NEE · Compliant: NEE
Beheerderhandeling zonder traceerbaarheid; direct NEN-8.15 schending

Wachtwoord wijzigen — HOOG

Locatie: OptionsFormController / ChangePasswordFormController · Gelogd: NEE · Compliant: NEE
Geen log bij succes of mislukking; niet te koppelen aan incident

voidPatient — KRITIEK

Locatie: PatientListController:70 · Gelogd: NEE · Compliant: NEE
Aanroep voidPatient(..., "") — lege reden, geen audit-trail

unvoidPatient — HOOG

Locatie: PatientFormController:278 · Gelogd: NEE · Compliant: NEE
Symmetrisch met void: geen logging bij herstel

updatePatient — HOOG

Locatie: DWRPatientService:634 · Gelogd: NEE · Compliant: NEE
DWR-laag omzeilt controller-logging; geen audit-entry

Brute-force (wachtwoordherstel) — HOOG

Locatie: ForgotPasswordFormController:59 · Gelogd: NEE · Compliant: NEE
Teller in-memory; verdwijnt bij herstart; niet aantoonbaar voor auditor

Module laden / starten — MIDDEL

Locatie: ModuleListController · Gelogd: DEELS · Compliant: DEELS
Technische fouten worden gelogd (warn); succesvolle start niet

Credential in request-param — KRITIEK

Locatie: PostHl7Controller:39-41 · Gelogd: N.v.t. · Compliant: NEE
Context.authenticate(username, password) via GET/POST param; log-risico + exposure

4. Gat: huidige situatie vs. gewenste situatie (NEN-7510 §8.15)

Aspect	Huidig	Gewenst (§8.15)	GAT
Authenticatie-events	Niet gelogd	Login succes + falen vastleggen met tijdstempel, gebruiker, IP	Volledig afwezig
Autorisatiefouten	Niet gelogd	Geweigerde toegang (privilege) vastleggen met resource en actor	Volledig afwezig
Gebruikersbeheer	Niet gelogd	create/delete/changePassword met actor, tijdstempel, betrokken gebruiker	Volledig afwezig
Patiëntmutaties	Niet gelogd	void/unvoid/update met actor, reden, tijdstempel, patiënt-ID (niet NAW)	Volledig afwezig
Persistentie brute-force teller	In-memory (reset bij herstart)	Persistente opslag; mislukte pogingen aantoonbaar na incident	Niet persistent
Gevoelige data in logs	Niet van toepassing (niets wordt gelogd)	Logs mogen geen PGI/PHI bevatten; logsysteem gescheiden	N.v.t. — risico bij implementatie
Beheerhandelingen (module, scheduler)	Deels (technische fouten)	Alle start/stop/config-wijzigingen vastleggen met actor	Gedeeltelijk gedekt

5. Conclusie

De LegacyUI-module heeft **nagenoeg geen security-logging**. Van de 13 geïnterviewde beveiligingsgerelateerde events worden er **11 niet gelogd**, 1 gedeeltelijk, en 1 correct. Dit is een directe schending van NEN-7510:2024-2 §8.15, dat vereist dat authenticatie, autorisatiefouten en beheermutaties aantoonbaar worden vastgelegd.

Vier events zijn geclassificeerd als **KRITIEK** (login-falen, createUser, voidPatient, plaintext credential in request-parameter) omdat ze direct raken aan non-repudiation en patiëntveiligheid. Een implementatieprioriteit conform §8.15 vereist minimaal: (1) persistente logging van authenticatie-events, (2) audit-trail voor gebruikers- en patiëntmutaties zonder PGI in de logregel, en (3) verwijdering van credentials als request-parameters.